数据库设计与开发
Database Design & Development

计算机学院　单纯
sherryshan@bit.edu.cn
2024年3月

数据库的安全性
Database Security

计算机学院　单纯
sherryshan@bit.edu.cn
2024年5月

数据库的安全性（1）

- 问题的提出
  - 数据库的一大特点是数据可以共享
  - 数据共享必然带来数据库的安全性问题
  - 数据库系统中的数据共享不能是无条件的共享
    - 例：军事秘密、国家机密、新产品实验数据、市场需求分析、市场营销策略、销售计划、客户档案、医疗档案、银行储蓄数据

数据库的安全性（2）

- 问题的提出（续）
  - 数据库中数据的共享是在DBMS统一的严格的控制之下的共享，即只允许有合法使用权限的用户访问允许他存取的数据
  - 数据库系统的安全保护措施是否有效是数据库系统主要的性能指标之一

数据库的安全性（3）

- 数据库管理系统需要提供数据保护功能保证数据的安全可靠和正确有效
- 数据保护包括两个含义：数据库的安全性和数据的完整性
- 数据库安全性是保护数据库不被非法使用和防止非法用户恶意破坏。安全性措施的防范对象是非法用户的进入和合法用户的非法操作

数据库的安全性（4）

- 什么是数据库的安全性
  - 数据库的安全性是指保护数据库，防止因用户非法使用数据库造成数据泄露、更改或破坏
- 什么是数据的保密
  - 数据保密是指用户合法地访问到机密数据后能否对这些数据保密
  - 通过制订法律道德准则和政策法规来保证

内容概览（1）

- 8.1 计算机安全性概述
- 8.2 数据库安全性概述
- 8.3 用户标识与鉴别
- 8.4 存取控制
- 8.5 视图机制

内容概览（2）

- 8.6 数据加密
- 8.7 数据库审计
- 8.8 统计数据库的安全性
- 8.9 小结

8.1 计算机安全性概述

- 8.1.1 计算机系统的三类安全性问题
- 8.1.2 安全标准简介

8.1.1 计算机系统的三类安全性问题 （1）

- 计算机系统安全性
  - 为计算机系统建立和采取的各种安全保护措施，以保护计算机系统中的硬件、软件及数据，防止其因偶然或恶意的原因使系统遭到破坏，数据遭到更改或泄露等

8.1.1 计算机系统的三类安全性问题 （2）

- 计算机安全涉及的问题
  - 计算机系统本身的技术问题
    - 计算机安全理论与策略
    - 计算机安全技术
  - 管理问题
    - 安全管理
    - 安全评价
    - 安全产品

8.1.1 计算机系统的三类安全性问题 （3）

- 计算机安全涉及的问题（续）
  - 法学
    - 计算机安全法律
  - 犯罪学
    - 计算机犯罪与侦察
    - 安全监察
  - 心理学

8.1.1 计算机系统的三类安全性问题 （4）

- 三类计算机系统安全性问题
  - 技术安全类
    - 指计算机系统中采用具有一定安全性的硬件、软件来实现对计算机系统及其所存数据的安全保护，当计算机系统受到无意或恶意的攻击时仍能保证系统正常运行，保证系统内的数据不增加、不丢失、不泄露

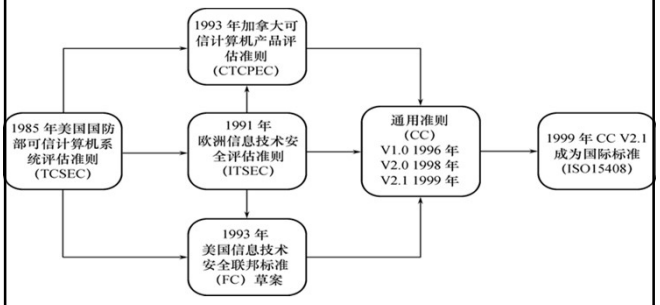
8.1.1 计算机系统的三类安全性问题 （5）

- 三类计算机系统安全性问题（续）
  - 管理安全类
    - 软硬件意外故障、场地的意外事故、管理不善导致的计算机设备和数据介质的物理破坏、丢失等安全问题
  - 政策法律类
    - 政府部门建立的有关计算机犯罪、数据安全保密的法律道德准则和政策法规、法令

8.1.2 安全标准简介

一、信息安全标准的发展历史
二、TCSEC标准
三、CC标准

一、信息安全标准的发展历史



二、TCSEC标准（1）

- 1985年美国国防部（DoD）正式颁布《DoD可信计算机系统评估标准》（简称TCSEC或DoD85）
  - TCSEC又称桔皮书
  - TCSEC标准的目的
    - 提供一种标准，使用户可以对其计算机系统内敏感信息安全操作的可信程度做评估
    - 给计算机行业的制造商提供一种可循的指导规则，使其产品能够更好地满足敏感应用的安全需求

二、TCSEC标准（2）

- 1991年4月美国NCSC（国家计算机安全中心）颁布了《可信计算机系统评估标准关于可信数据库系统的解释》（Trusted Database Interpretation 简称TDI）
  - TDI又称紫皮书。它将TCSEC扩展到数据库管理系统
  - TDI中定义了数据库管理系统的设计与实现中需满足和用以进行安全性级别评估的标准

二、TCSEC标准（3）

- TCSEC/TDI标准的基本内容
  - 从四个方面来描述安全性级别划分的指标
    - 安全策略
    - 责任
    - 保证
    - 文档

二、TCSEC标准（4）

- TCSEC/TDI安全级别划分

安全级别	定　义
A1	验证设计（Verified Design）
B3	安全域（Security Domains）
B2	结构化保护（Structural Protection）
B1	标记安全保护（Labeled Security Protection）
C2	受控的存取保护（Controlled Access Protection）
C1	自主安全保护（Discretionary Security Protection）
D	最小保护（Minimal Protection）

二、TCSEC标准（5）

- TCSEC/TDI安全级别划分（续）
  - 四组（division）七个等级
    - D
    - C（C1，C2）
    - B（B1，B2，B3）
    - A（A1）
  - 按系统可靠或可信程度逐渐增高
  - 各安全级别之间具有一种偏序向下兼容的关系，即较高安全性级别提供的安全保护要包含较低级别的所有保护要求，同时提供更多或更完善的保护能力

1. D级

- 提供最小保护（Minimal Protection），将一切不符合更高标准的系统均归于D组
- 典型例子：DOS是安全标准为D的操作系统
  - DOS在安全性方面几乎没有什么专门的机制来保障

2. C1级

- 非常初级的自主安全保护（Discretionary Security Protection）
- 能够实现对用户和数据的分离，进行自主存取控制（Discretionary Access Control，DAC），保护或限制用户权限的传播

3. C2级（1）

- 安全产品的最低档次
- 提供受控的存取保护（Controlled Access Protection），将C1级的DAC（自主存取控制）进一步细化，以个人身份注册负责，并实施审计和资源隔离
- 达到C2级的产品在其名称中往往不突出“安全”（Security）这一特色

3. C2级（2）

- 典型例子
  - 操作系统
    - Microsoft的Windows
  - 数据库
    - Oracle公司的Oracle

4. B1级（1）

- 标记安全保护（Labeled Security Protection）。“安全”（Security）或“可信的”（Trusted）产品
- 对系统的数据加以标记，对标记的主体和客体实施强制存取控制（Mandatory Access Control，MAC）、审计等安全机制

4. B1级（2）

- 典型例子
  - 操作系统
    - 惠普公司的HP-UX BLS
  - 数据库
    - Oracle公司的Trusted Oracle

5. B2级（1）

- 结构化保护（Structural Protection）
- 建立形式化的安全策略模型并对系统内的所有主体和客体实施DAC（自主存取控制）和MAC（强制存取控制）
- 经过认证的B2级以上的安全系统非常稀少

5. B2级（2）

- 典型例子
  - 操作系统
    - Trusted Information Systems公司的Trusted XENIX
  - 数据库
    - 没有符合B2标准的产品

6. B3级

- 安全域保护（Security Domains）
- 该级的可信任运算基础（Trusted Computing Base，TCB）必须满足访问监控器的要求，审计跟踪能力更强，并提供系统恢复过程

7. A1级

- 验证设计（Verified Design），即提供B3级保护的同时给出系统的形式化设计说明和验证以确信各安全保护真正实现

二、TCSEC标准（6）

- TCSEC/TDI安全级别划分（续）
  - 四组（division）七个等级
    - B2以上的系统
      - 还处于理论研究阶段
      - 应用多限于一些特殊的部门，如军队等
      - 美国正在大力发展安全产品，试图将目前仅限于少数领域应用的B2安全级别下放到商业应用中来，并逐步成为新的商业标准

三、CC标准（1）

- 1983年一个被称为CC（Common Criteria）项目的行动被发起，主要目的是解决各标准中概念和技术上的差异，将各自独立的准则集合成一组单一的、能被广泛使用的IT安全准则
- CC V2.1版于1999年被ISO采用为国标标准，2001年被我国采用为国家标准

三、CC标准（2）

- 目前，CC已经基本取代了TCSEC成为评估信息产品安全性的主要标准。CC提出了目前国际上公认的表述信息技术安全性的结构，把信息安全产品的安全要求分为安全功能要求和安全保证要求。CC中，根据系统对安全保证要求的情况提出了评估保证级（EAL），从EAL1至EAL7共分为七级，按保证程度逐渐增高
- 目前有许多信息产品都已经通过了CC的EAL4级

三、CC标准（3）

- 访问控制矩阵

评估保证级	定　义	TCSEC 安全级别（近似相当）
EAL1	功能测试(functionally tested)	
EAL2	结构测试(structurally tested)	C1
EAL3	系统地测试和检查(methodically tested and checked)	C2
EAL4	系统地设计、测试和复查(methodically designed, tested, and reviewed)	B1
EAL5	半形式化设计和测试(semiformally designed and tested)	B2
EAL6	半形式化验证的设计和测试(semiformally verified design and tested)	B3
EAL7	形式化验证的设计和测试(formally verified design and tested)	A1

8.2 数据库安全性概述（1）

- 非法使用数据库的情况
  - 用户编写一段合法的程序绕过DBMS及其授权机制，通过操作系统直接存取、修改或备份数据库中的数据
  - 直接或编写应用程序执行非授权操作

8.2 数据库安全性概述（2）

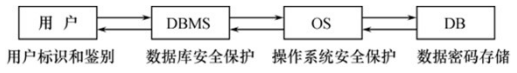
- 非法使用数据库的情况（续）
  - 通过多次合法查询数据库，从中推导出一些保密数据
    - 例：某数据库应用系统禁止查询单个人的工资，但允许查任意一组人的平均工资。用户甲想了解张三的工资，于是他
      - 首先查询包括张三在内的一组人的平均工资
      - 然后查用自己替换张三后这组人的平均工资
      - 从而推导出张三的工资
  - 破坏安全性的行为可能是无意的、故意的、恶意的

8.2 数据库安全性概述（3）

- 数据库的安全性层次
  - 数据库系统层
    - 数据库系统只允许获得授权的用户访问权限范围内的数据，权限范围外的数据不允许访问和修改
  - 操作系统层
    - 操作系统有自己的安全保护措施。不管数据库有多安全，操作系统安全性方面的弱点也会造成数据的安全隐患

8.2 数据库安全性概述（4）

- 数据库的安全性层次（续）
  - 网络层
    - 几乎所有的数据库系统都允许通过终端或网络进行远程访问，网络层的安全同样需要考虑
- 计算机系统的安全模型



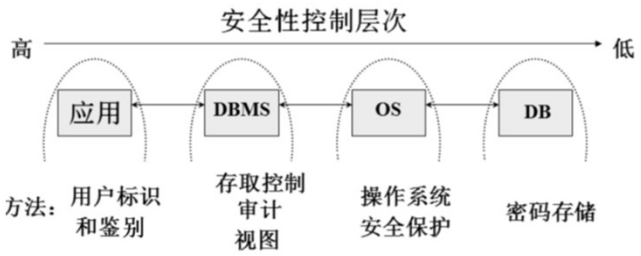
8.2 数据库安全性概述（5）

- 数据库系统所采用的安全技术
  - 访问控制技术
    - 防止未授权的用户访问系统
    - 所有计算机系统都存在
    - 访问控制技术主要通过创建用户账号和口令、由DBMS控制登录过程来实现
  - 存取控制技术
    - DBMS必须提供相应的技术保证用户只能访问权限范围内的数据，不能访问数据库的其他内容

8.2 数据库安全性概述（6）

- 数据库系统所采用的安全技术（续）
  - 数据加密技术
    - 用于保护敏感数据的传输和存储，可以对数据库的敏感数据提供额外的保护
  - 数据库审计
    - 在数据库系统运行期间，记录数据库的访问情况，以利用审计数据分析数据库是否受到非法存取

8.2 数据库安全性概述（7）



8.3 用户标识与鉴别

- 用户标识和鉴别是保证数据库安全性的最简单、最基本的措施，也是系统提供的最外层安全保护措施
- 基本方法
  - 任何对数据库系统的访问都需要通过用户标识来获得授权，拥有数据库登录权限的用户才能进入数据库管理系统
  - 常用的方法是采用用户名（user name）或用户帐号（user account），以及口令（password）来标识用户身份

8.4 存取控制（1）

- 存取控制机制的功能
  - 存取控制机制的组成
    - 定义存取权限
      - 在数据库系统中，为了保证用户只能访问他有权存取的数据，必须预先对每个用户定义存取权限
    - 检查存取权限
      - 对于通过鉴定获得上机权的用户（即合法用户），系统根据他的存取权限定义对他的各种操作请求进行控制，确保他只执行合法操作
    - 用户权限定义和合法权限检查机制一起组成了DBMS的安全子系统

8.4 存取控制（2）

- 常用存取控制方法
  - 自主存取控制（Discretionary Access Control，简称DAC）
    - C2级、灵活
    - 同一用户对于不同的数据对象有不同的存取权限
    - 不同的用户对同一对象也有不同的权限
    - 用户还可将其拥有的存取权限转授给其他用户

8.4 存取控制（3）

- 常用存取控制方法（续）
  - 强制存取控制（Mandatory Access Control，简称 MAC）
    - B1级、严格
    - 每一个数据对象被标以一定的密级
    - 每一个用户也被授予某一个级别的许可证
    - 对于任意一个对象，只有具有合法许可证的用户才可以存取

8.4.1 自主存取控制（1）

- 定义存取权限
  - 存取权限
    - 存取权限由两个要素组成
      - 数据对象
      - 操作类型

8.4.1 自主存取控制（2）

- 定义存取权限（续）
  - 关系系统中的存取权限
    - 类型

对象类型	对象	操作类型
数据库	模式	CREATE SCHEMA
	基本表	CREATE TABLE，ALTER TABLE
模式	视图	CREATE VIEW
	索引	CREATE INDEX
数据	基本表和视图	SELECT，INSERT，UPDATE，DELETE，REFERENCES，ALL PRIVILEGES
数据	属性列	SELECT，INSERT，UPDATE，REFERENCES ALL PRIVILEGES

    - 定义方法
      - GRANT/REVOKE

8.4.1 自主存取控制（3）

- 检查存取权限
  - 对于获得上机权后又进一步发出存取数据库操作的用户
    - DBMS查找数据字典，根据其存取权限对操作的合法性进行检查
    - 若用户的操作请求超出了定义的权限，系统将拒绝执行此操作

8.4.1 自主存取控制（4）

- 授权粒度
  - 授权粒度是指可以定义的数据对象的范围
    - 它是衡量授权机制是否灵活的一个重要指标
    - 授权定义中数据对象的粒度越细，即可以定义的数据对象的范围越小，授权子系统就越灵活

8.4.1 自主存取控制（5）

- 授权粒度（续）
  - 关系数据库中授权的数据对象粒度
    - 数据库
    - 表
    - 属性列
    - 行
  - 能否提供与数据值有关的授权反映了授权子系统精巧程度

8.4.1 自主存取控制（6）

- 实现与数据值有关的授权
  - 利用存取谓词
    - 存取谓词可以很复杂
      - 可以引用系统变量，如终端设备号，系统时钟等，实现与时间地点有关的存取权限，这样用户只能在某段时间内，某台终端上存取有关数据
        - 例：规定“教师只能在每年1月份和7月份星期一至星期五上午8点到下午5点处理学生成绩数据”

8.4.1 自主存取控制（7）

一、自主存取控制的实现
二、数据库角色
三、权限的传播
四、自主存取控制小结

一、自主存取控制的实现

- 大型数据库管理系统几乎都支持自主控制存取
- SQL标准通过GRANT和REVOKE实现自主存取控制

二、数据库角色（1）

- 在用户数量比较大的情况下，为了便于权限管理，需要引入角色的概念
- 数据库角色：被命名的一组与数据库操作相关的权限
  - 角色是权限的集合
  - 可以为一组具有相同权限的用户创建一个角色
  - 简化授权的过程

二、数据库角色（2）

1. 角色的创建
2. 给角色授权
3. 将一个角色授予其他的角色或用户
4. 角色权限的收回

1. 角色的创建

CREATE ROLE <角色名>

2. 给角色授权

GRANT <权限>[，<权限>]…
ON <对象类型>对象名
TO <角色>[，<角色>]…

3. 将一个角色授予其他的角色或用户

GRANT <角色1>[，<角色2>]…
TO <角色3>[，<用户1>]…
[WITH ADMIN OPTION]

4. 角色权限的收回

REVOKE <权限>[，<权限>]…
ON <对象类型> <对象名>
FROM <角色>[，<角色>]…

例题（1）

- 用户Wang通过角色实现将一组授权授予用户Li和Zhao
  - 首先，Wang创建一个角色R1

    CREATE ROLE R1；
  - Wang授予角色R1拥有Student、SC和Course三个关系的查询权限

    GRANT SELECT
    ON TABLE STUDENT, SC, COURSE
    TO R1；

例题（2）

- Wang将角色R1授予用户Li和Zhao，使他们具有角色R1所包含的全部权限

  GRANT R1
  TO Li, Zhao；

三、权限的传播

- SQL灵活的授权机制
  - DBA：拥有所有对象的所有权限
    - 不同的权限授予不同的用户
  - 用户：拥有自己建立的对象的全部的操作权限
    - GRANT：授予其他用户
  - 被授权的用户
    - “继续授权”许可：再授予
  - 所有授予出去的权力在必要时又都可用REVOKE语句收回

四、自主存取控制小结（1）

- 定义存取权限
  - 用户
- 检查存取权限
  - DBMS
- 授权粒度
  - 数据对象粒度：数据库、表、属性列、行

四、自主存取控制小结（2）

- 数据值粒度：存取谓词
  - 授权粒度越细，授权子系统就越灵活，能够提供的安全性就越完善。但另一方面，因数据字典变大变复杂，系统定义与检查权限的开销也会相应地增大
- 优点
  - 能够通过授权机制有效地控制其他用户对敏感数据的存取

四、自主存取控制小结（3）

- 缺点
  - 可能存在数据的“无意泄露”
    - 原因：这种机制仅仅通过对数据的存取权限来进行安全控制，而数据本身并无安全性标记
    - 解决：对系统控制下的所有主客体实施强制存取控制策略

8.4.2 强制存取控制（1）

- 什么是强制存取控制
  - 强制存取控制（MAC）是指系统为保证更高程度的安全性，按照TDI/TCSEC标准中安全策略的要求，所采取的强制存取检查手段
  - MAC不是用户能直接感知或进行控制的
  - MAC适用于对数据有严格而固定密级分类的部门
    - 军事部门
    - 政府部门

8.4.2 强制存取控制（2）

- 主体与客体
  - 在MAC中，DBMS所管理的全部实体被分为主体和客体两大类
    - 主体是系统中的活动实体
      - DBMS所管理的实际用户
      - 代表用户的各进程
    - 客体是系统中的被动实体，是受主体操纵的
      - 文件
      - 基表
      - 索引
      - 视图

8.4.2 强制存取控制（3）

- 敏感度标记
  - 对于主体和客体，DBMS为它们每个实例（值）指派一个敏感度标记（Label）
  - 敏感度标记分成若干级别
    - 绝密（Top Secret）
    - 机密（Secret）
    - 可信（Confidential）
    - 公开（Public）

8.4.2 强制存取控制（4）

- 敏感度标记（续）
  - 主体的敏感度标记称为许可证级别（Clearance Level）
  - 客体的敏感度标记称为密级（Classification Level）
  - MAC机制就是通过对比主体的Label和客体的Label，最终确定主体是否能够存取客体

8.4.2 强制存取控制（5）

- 强制存取控制规则
  - 当某一用户（或某一主体）以标记Label注册进入系统时，系统要求他对任何客体的存取必须遵循下面两条规则
    - 仅当主体的许可证级别大于或等于客体的密级时，该主体才能读取相应的客体
    - 仅当主体的许可证级别等于客体的密级时，该主体才能写相应的客体

8.4.2 强制存取控制（6）

- 修正规则
  - 主体的许可证级别 ≤客体的密级
    - 主体能写客体
  - 用户可为写入的数据对象赋予高于自己的许可证级别的密级
  - 一旦数据被写入，该用户自己也不能再读该数据对象
- 规则的共同点
  - 禁止了拥有高许可证级别的主体更新低密级的数据对象

8.4.2 强制存取控制（7）

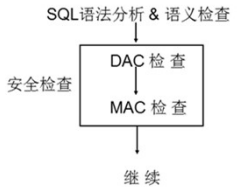
- 强制存取控制的特点
  - MAC是对数据本身进行密级标记
  - 无论数据如何复制，标记与数据是一个不可分的整体
  - 只有符合密级标记要求的用户才可以操纵数据，从而提供了更高级别的安全性

MAC与DAC（1）

- DAC（自主存取控制）与MAC（强制存取控制）共同构成DBMS的安全机制
- 实现MAC时要首先实现DAC
  - 原因：较高安全性级别提供的安全保护要包含较低级别的所有保护

MAC与DAC（2）

- DAC + MAC安全检查示意图



  - 先进行DAC检查，通过DAC检查的数据对象再由系统进行MAC检查，只有通过MAC检查的数据对象方可存取

8.5 视图机制（1）

- 使用视图可以实现下列功能
  - 将用户限定在数据表中特定的数据行上
  - 将用户限定在数据表中特定的数据列上
  - 将多个表中的列连接起来，使他们看起来像一个数据表
  - 聚合信息而非提供详细信息

8.5 视图机制（2）

- 视图机制把要保密的数据对无权存取这些数据的用户隐藏起来
- 视图机制更主要的功能在于提供数据独立性，其安全保护功能太不精细，往往远不能达到应用系统的要求
- 视图机制与授权机制配合使用
  - 首先用视图机制屏蔽掉一部分保密数据
  - 视图上面再进一步定义存取权限
  - 间接实现了支持存取谓词的用户权限定义

8.6 数据加密（1）

- 数据加密
  - 防止数据库中数据在存储和传输中失密的有效手段
- 加密的基本思想
  - 根据一定的算法将原始数据（术语为明文，Plain text）变换为不可直接识别的格式（术语为密文，Cipher text）
  - 不知道解密算法的人无法获知数据的内容

8.6 数据加密（2）

- 加密方法
  - 替换方法
    - 使用密钥（Encryption Key）将明文中的每一个字符转换为密文中的一个字符
  - 置换方法
    - 将明文的字符按不同的顺序重新排列
  - 混合方法
    - 美国1977年制定的官方加密标准：数据加密标准（Data Encryption Standard，简称DES）

8.6 数据加密（3）

- DBMS中的数据加密
  - 有些数据库产品提供了数据加密例行程序
  - 有些数据库产品本身未提供加密程序，但提供了接口
- 数据加密功能通常也作为可选特征，允许用户自由选择
  - 数据加密与解密是比较费时的操作
  - 数据加密与解密程序会占用大量系统资源
  - 应该只对高度机密的数据加密

8.6 数据加密（4）

- 数据库加密技术的特点
  - 数据加密后的存储空间应该不能有明显的改变
  - 对加密和解密的时间要求更高，加密和解密的速度会影响数据库的可用性
  - 加密机制应当考虑用户在存取数据粒度上的不同要求，对数据库中的数据进行不同粒度上的加密处理，并且结合灵活的授权机制，有利于多用户对数据的共享

8.7 数据库审计（1）

- 什么是审计
  - 审计日志（Audit Log）
    - 将用户对数据库的所有操作记录在上面
  - DBA利用审计日志
    - 找出非法存取数据的人、时间和内容
  - C2以上安全级别的DBMS必须具有

8.7 数据库审计（2）

- 审计分为
  - 用户级审计
    - 针对自己创建的数据库表或视图进行审计
    - 记录所有用户对这些表或视图的一切成功和（或）不成功的访问要求以及各种类型的SQL操作
  - 系统级审计
    - DBA设置
    - 监测成功或失败的登录要求
    - 监测GRANT和REVOKE操作以及其他数据库级权限下的操作

8.7 数据库审计（3）

- AUDIT语句：设置审计功能
  - 对修改SC表结构或修改SC表数据的操作进行审计

    AUDIT ALTER，UPDATE
    ON SC；
- NOAUDIT语句：取消审计功能
  - 取消对SC表的一切审计

    NOAUDIT ALTER，UPDATE
    ON SC；

8.7 数据库审计（4）

- 数据库审计功能一般主要用于安全性要求较高的部门
- 审计通常是很费时间和空间的，所以DBMS往往都将其作为可选特征，允许DBA根据应用对安全性的要求，灵活地打开或关闭审计功能

8.8 统计数据库的安全性（1）

- 统计数据库的特点
  - 允许用户查询聚集类型的信息（例如合计、平均值等）
  - 不允许查询单个记录信息
    - 例：允许查询“程序员的平均工资是多少？”
      不允许查询“程序员张勇的工资是多少？”
- 统计数据库中特殊的安全问题
  - 隐蔽的信息通道
  - 从合法的查询中推导出不合法的信息

8.8 统计数据库的安全性（2）

- 下面两个查询都是合法的
  - 本公司共有多少女高级程序员？
  - 本公司女高级程序员的工资总额是多少？
    - 如果第一个查询的结果是“1”
    - 那么第二个查询的结果显然就是这个程序员的工资数
- 规则1：任何查询至少要涉及N（N足够大）个以上的记录

8.8 统计数据库的安全性（3）

- 用户A发出下面两个合法查询
  - 用户A和其他N个程序员的工资总额是多少？
  - 用户B和其他N个程序员的工资总额是多少？
    - 若第一个查询的结果是X，第二个查询的结果是Y
    - 由于用户A知道自己的工资是Z
    - 那么他可以计算出用户B的工资=Y-（X-Z）
      - 原因：两个查询之间有很多重复的数据项
- 规则2：任意两个查询的相交数据项不能超过M个

8.8 统计数据库的安全性（4）

- 可以证明，在上述两条规定下，如果想获知用户B的工资额
  - A至少需要进行1+（N-2）/M次查询
- 规则3：任一用户的查询次数不能超过1+（N-2）/M
  - 如果两个用户合作查询就可以使这一规定失效
- 数据库安全机制的设计目标
  - 试图破坏安全的人所花费的代价 >>得到的利益

8.9 小结（1）

- 随着计算机网络的发展，数据的共享日益加强，数据的安全保密越来越重要
- DBMS是管理数据的核心，因而其自身必须具有一整套完整而有效的安全性机制

8.9 小结（2）

- TCSEC/TDI从安全策略、责任、保证和文档四个方面描述了安全性级别的指标
  - 目前许多大型DBMS达到了C2级，其安全版本达到了B1级
    - C2级的DBMS必须具有自主存取控制功能和初步的审计功能
    - B1级的DBMS必须具有强制存取控制和增强的审计功能

8.9 小结（3）

- 实现数据库系统安全性的技术和方法
  - 存取控制技术
  - 视图技术
  - 审计技术
- 自主存取控制功能
  - 通过SQL的GRANT语句和REVOKE语句实现
- 角色
  - 使用角色来管理数据库权限可以简化授权过程
  - CREATE ROLE语句创建角色
  - GRANT语句给角色授权

参考资料

- 第6章，周志逵 郭贵锁等编著，数据库系统原理，北京：清华大学出版社，2008
- 第四章，王珊 萨师煊，数据库系统概论（第5版）， 北京：高等教育出版社，2014

Thank You